

L2 - 7.7. Tactical-Detection(Legacy)

Task 1 - Introduction

In this room, we will strive to understand the mindset behind choosing a tactical approach in alerting and detecting threats, IOAs, IOCs, etc. In the process, we will gain practical experience in setting up a basic tactical detection capability leveraging techniques used in real-life environments.

Task 2 - Unique Threat Intel

Unique IOCs of previous intrusions are good examples of Threat Intel as they're traces of the specific adversary that your environment has already faced. The inclusion of these IOCs in your detection mechanism will help spot re-intrusion of that specific adversary immediately, among others.

File Name	Path	File Size	Description
bad3xe69.exe	C:\Downloads\bad3xe69.exe	13619KB	Downloaded from the internet. Posing as an installer for an application that needs an update.

DNS/IP Address	Description
bad3xe69connection.io	Domain of the source of the malicious executable bad3xe69.exe
kind4bad.com	Suspicious domain related to bad3xe69connection.io
nic3connection.io	Suspicious domain related to bad3xe69connection.io

Unique IOCs of previous intrusions are good examples of Threat Intel as they're traces of the specific adversary that your environment has already faced. The inclusion of these IOCs in your detection mechanism will help spot re-intrusion of that specific adversary immediately, among others.

File Name	Path	File Size	Description
bad3xe69.exe	C:\Downloads\bad3xe69.exe	13619KB	Downloaded from the internet. Posing as an installer for an application that needs an update.

DNS/IP Address	Description
bad3xe69connection.io	Domain of the source of the malicious executable bad3xe69.exe
kind4bad.com	Suspicious domain related to bad3xe69connection.io
nic3connection.io	Suspicious domain related to bad3xe69connection.io

To maximize our efficiency, we will transform these IOCs into detection rules in a vendor-agnostic format using **Sigma**.

Sigma is an open-source generic signature language developed to describe log events in a structured format. This allows for quick sharing of detection methods by security analysts.

A basic example of how it can be written into a functional Sigma rule is as follows.

baddomains.yml

```

title: Executable Download from Suspicious Domains
status: test
description: Detects download of executable types from hosts found in the IOC spreadsheet
author: Mokmokmok
date: 2022/08/23
modified: 2022/08/23
logsource:
  category: proxy
detection:
  selection:
    c-uri-extension:
      - 'exe'
    r-dns:
      - 'bad3xe69connection.io'
      - 'kind4bad.com'
      - 'nic3connection.io'
  condition: selection
fields:
  - c-uri

```

```
falsepositives:  
  - Unkown  
level: medium
```

The Sigma rule that we came up with from the IOCs presented above is very simple and straightforward, yet the additional layer of detection that it gives the organization is invaluable. In the grander scheme of things, these layers work together to give your analysts the visibility that they need to spot bad actors before it's too late.

Answer the questions below

What did we use to transform IOCs as detection rules in a vendor-agnostic format? Sigma

What is the original indicator found by the authors of the documentation? Write it as written in the spreadsheet.[bad3xe69connection.io](#) (written above in baddomains.yml)

What is the full file path of the malicious file downloaded from the internet?
C:\Downloads\bad3xe69.exe

In the Sigma Rule baddomains.yml, what is the logsource category used by the author? proxy

Task 3 - Publicly Generated IOCs

We've leveraged Sigma to transform unique IOCs into a product-agnostic form that we can use regardless of our SIEM choice. As this technique shows great promise to the community, there are a number of nice repositories that contain user-submitted Sigma rules that anyone can use. You can plug one directly into your SIEM for immediate value, or further edit it to fit your environment and add even more value to your security posture.

The following is a nice exercise: Write a detection rule for these two / transform these publicly generated IOCs into usable alerts for use in the Elastic Stack and Splunk. We will do the first one together, while you can do the rest on your own. For our purposes, we will be using [Uncoder\(opens in new tab\)](#) to help with the transformation of these sigma rules. Uncoder is a nice tool that helps convert sigma rules to queries that can be immediately used within a SIEM of your choice.

A fairly recent 0-day vulnerability, Follina-MSDT, has a publicly available sigma rule developed by huntress's Matthew Brennan:

Follina-MSDT Sigma Rule

```
title: Suspicious msdt.exe execution - Office Exploit
id: 97a80ed7-1f3f-4d05-9ef4-65760e634f6b
status: experimental
description: This rule will monitor suspicious arguments passed to the msdt.exe process. These arguments are an indicator of recent Office/Msdt exploitation.
references:
  - https://doublepulsar.com/follina-a-microsoft-office-code-execution-vulnerability-1a47fce5629e
  - https://twitter.com/MalwareJake/status/1531019243411623939
author: 'Matthew Brennan'
tags:
  - attack.execution
logsource:
  category: process_creation
  product: windows
detection:
  selection1:
    Image|endswith:
      - 'msdt.exe'
  selection2:
    CommandLine|contains:
      - 'PCWDiagnostic'
  selection3:
    CommandLine|contains:
      - 'ms-msdt:-id'
      - 'ms-msdt:/id'
  selection4:
    CommandLine|contains:
```

```
- 'invoke'
  condition: selection1 and (selection4 or (selection2 and s
election3))
falsepositives:
  - Unknown
level: high
```

Another 0-day vulnerability that made waves this past year, log4j, has multiple publicly available sigma rules. One such rule can detect suspicious shells(opens in new tab), spawned from a Java host process, written by Andreas Hunkeler and Florian Roth:

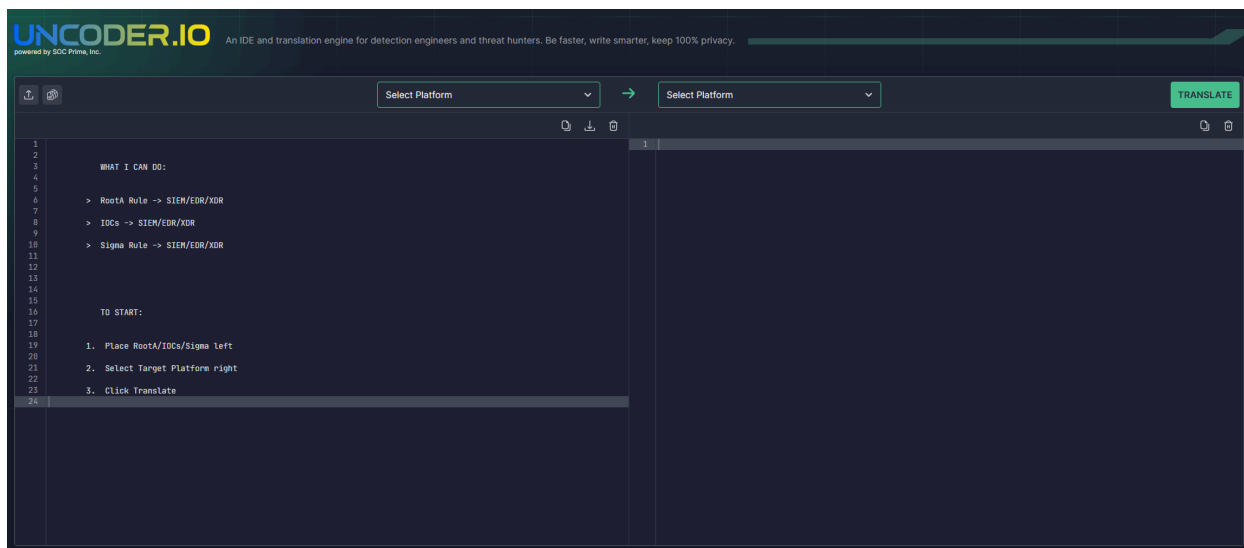
Log4j Suspicious Shells Sigma Rule

```
title: Suspicious Shells Spawned by Java
id: 0d34ed8b-1c12-4ff2-828c-16fc860b766d
description: Detects suspicious shell spawned from Java host p
rocess (e.g. log4j exploitation)
status: experimental
author: Andreas Hunkeler (@Karneades), Florian Roth
date: 2021/12/17
modified: 2022/08/02
tags:
  - attack.initial_access
  - attack.persistence
  - attack.privilege_escalation
logsource:
  category: process_creation
  product: windows
detection:
  selection:
    ParentImage|endswith: '\java.exe'
    Image|endswith:
      - '\sh.exe'
      - '\bash.exe'
      - '\powershell.exe'
      - '\pwsh.exe'
```

```
- '\schtasks.exe'
- '\certutil.exe'
- '\whoami.exe'
- '\bitsadmin.exe'
- '\wscript.exe'
- '\cscript.exe'
- '\scrcons.exe'
- '\regsvr32.exe'
- '\hh.exe'
- '\wmic.exe'          # https://app.any.run/tasks/c
903e9c8-0350-440c-8688-3881b556b8e0/
- '\mshta.exe'
- '\rundll32.exe'
- '\forfiles.exe'
- '\scriptrunner.exe'
- '\mftrace.exe'
- '\AppVLP.exe'
- '\curl.exe'

condition: selection
falsepositives:
  - Legitimate calls to system binaries
  - Company specific internal usage
level: high
```

Upon navigating to [Uncoder](#)([opens in new tab](#)), you will immediately see two text boxes, as shown below:

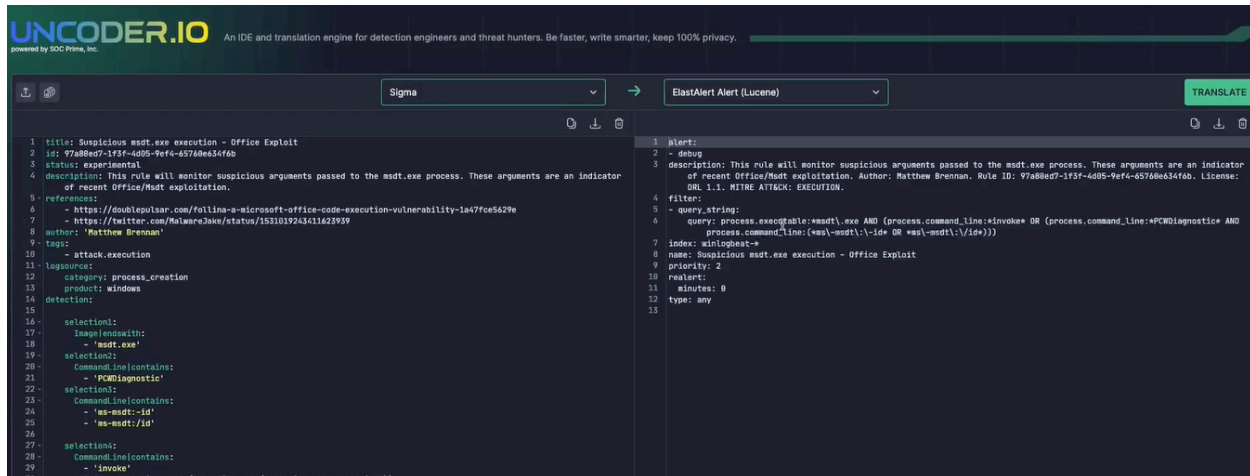


Make sure that on the left side, the Sigma tab is selected as shown above. Copy the Follina-MSDT Sigma Rule contents and then paste it in the left text box. Click on the downward arrow and select ElastAlert. Click on the *Translate* button when you're ready. Upon clicking Translate, it shouldn't take long before the results come out of the right text box.

It is important to note that there's no guarantee that the transformed Sigma rules will work perfectly straight out of Uncoder. In order to be production ready, you need to do a lot of testing and fine-tuning. What Uncoder essentially offers is a generic blueprint - it is up to the user to further improve upon it.

Answer the questions below

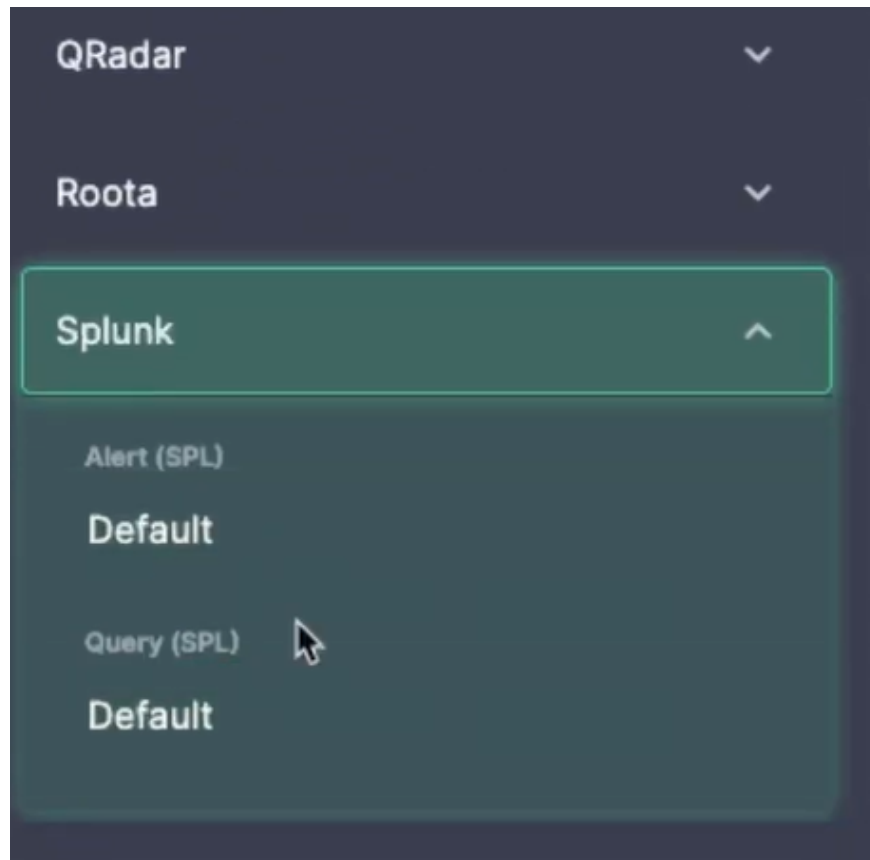
Upon translating the Follina Sigma Rule, what is the index name that the rule will be using, as shown in the output? winlogbeat-* (Write the given Follina-MSDT Sigma Rule in uncoder.io . translate and check index in text)



What is the Alerter subclass, as shown in the output? debug (alert:debug in uncoder.io)

Change the Uncoder output to Elastic Stack Query (Lucene). Which part of the ElastAlert output looks exactly like the Elastic Query? filter (filter where is given query details)

Translate the Log4j Sigma Rule into a Splunk Alert (SPL). What is the alert severity, as shown in the output? 3 (choose Splunk alert in uncoder.io)



```
Splunk Alert (SPL) TRANSLATE
[Suspicious Shells Spawned by Java]
alert.severity = 3
description = Detects suspicious shell spawned from Java host process (e.g. log4j exploitation). Author: Andreas Hunkeler (@Karneades), Florian Roth. Rule ID: 8d34ed8b-1c12-4ff2-828c-16fc860b766d. License: DRL 1.1.
cron_schedule = 0 * * * *
disabled = 1
is_scheduled = 1
is_visible = 1
dispatch.earliest_time = -60m@m
dispatch.latest_time = now
search = source=WinEventLog:Security AND (ParentImage="*\\java.exe" AND (Image="*\\sh.exe" OR Image="*\\bash.exe" OR Image="*\\powershell.exe" OR Image="*\\pwsh.exe" OR Image="*\\schtasks.exe" OR Image="*\\certutil.exe" OR Image="*\\whoami.exe" OR Image="*\\bitsadmin.exe" OR Image="*\\wscript.exe" OR Image="*\\cscript.exe" OR Image="*\\scrcons.exe" OR Image="*\\regsvr32.exe" OR Image="*\\hh.exe" OR Image="*\\mmic.exe" OR Image="*\\mshta.exe" OR Image="*\\rundll32.exe" OR Image="*\\forfiles.exe" OR Image="*\\scriptrunner.exe" OR Image="*\\mftrace.exe" OR Image="*\\AppVLP.exe" OR Image="*\\curl.exe"))
alert.suppress = 0
alert.track = 1
actions = risk,notable
action.risk = 1
action.risk.param._risk_object_type = user
action.risk.param._risk_score = 75
action.correlationsearch = 0
action.correlationsearch.enabled = 1
action.notable.param.rule_title = Suspicious Shells Spawned by Java
action.notable.param.rule_description = Detects suspicious shell spawned from Java host process (e.g. log4j exploitation). Author: Andreas Hunkeler (@Karneades), Florian Roth. Rule ID: 8d34ed8b-1c12-4ff2-828c-16fc860b766d. License: DRL 1.1.
action.correlationsearch.label = Suspicious Shells Spawned by Java
action.correlationsearch.annotations = {'mitre_attack': ['Initial Access', 'Persistence', 'Privilege Escalation']}
```

What is the dispatch.earliest_time value, as shown in the output? 60m@m (dispatch earliest time in picture above)

Change the Uncoder output to Splunk Query (SPL). What is the source, as shown in the output? WinEventLog:Security (Source:WinEventLog)

```
Splunk Query (SPL) TRANSLATE
1 source=WinEventLog:Security AND (ParentImage="*\\java.exe" AND (Image="*\\sh.exe" OR Image="*\\bash.exe" OR Image="*\\powershell.exe" OR Image="*\\pwsh.exe" OR Image="*\\schtasks.exe" OR Image="*\\certutil.exe" OR Image="*\\whoami.exe" OR Image="*\\bitsadmin.exe" OR Image="*\\wscript.exe" OR Image="*\\cscript.exe" OR Image="*\\scrcons.exe" OR Image="*\\regsvr32.exe" OR Image="*\\hh.exe" OR Image="*\\mmic.exe" OR Image="*\\mshta.exe" OR Image="*\\rundll32.exe" OR Image="*\\forfiles.exe" OR Image="*\\scriptrunner.exe" OR Image="*\\mftrace.exe" OR Image="*\\AppVLP.exe" OR Image="*\\curl.exe"))
2
3 ''' name: Suspicious Shells Spawned by Java '''
4 ''' uuid: 8d34ed8b-1c12-4ff2-828c-16fc860b766d '''
5 ''' author: Andreas Hunkeler (@Karneades), Florian Roth '''
6 ''' licence: DRL 1.1 '''
```

Task 4 - Leveraging "Know Your Environment": Tripwires

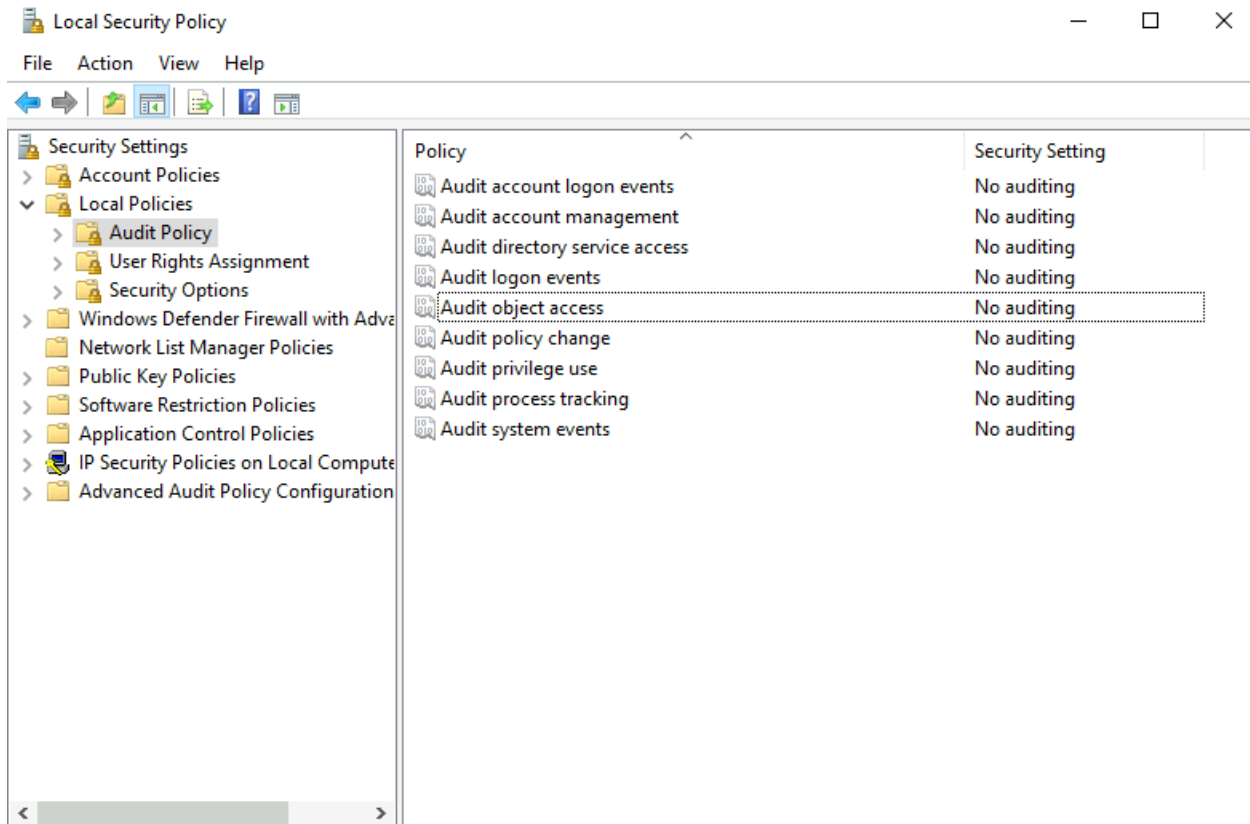
One way to create immediate impact is to leverage very specific data to your advantage. Depending on the environment/organization, more often than not, there exist pieces of data that not everyone is entitled to have access to. Usually, controls are set by the IT team to limit these accesses.

For example, suppose there are ultra-sensitive files your organization intends to keep secret, such as a hidden treasure map. In that case, you can set alerts for instances that the said map has been accessed, edited, and deleted among other things, and then filter out the ones allowed access to make detections more actionable.

Tripwires are a great way to supplement the detection mechanisms that you already have in place. It's a way to cover "unknown unknowns" and even study an adversary. The most common tripwires are Honeypots and Hidden Files and Folders.

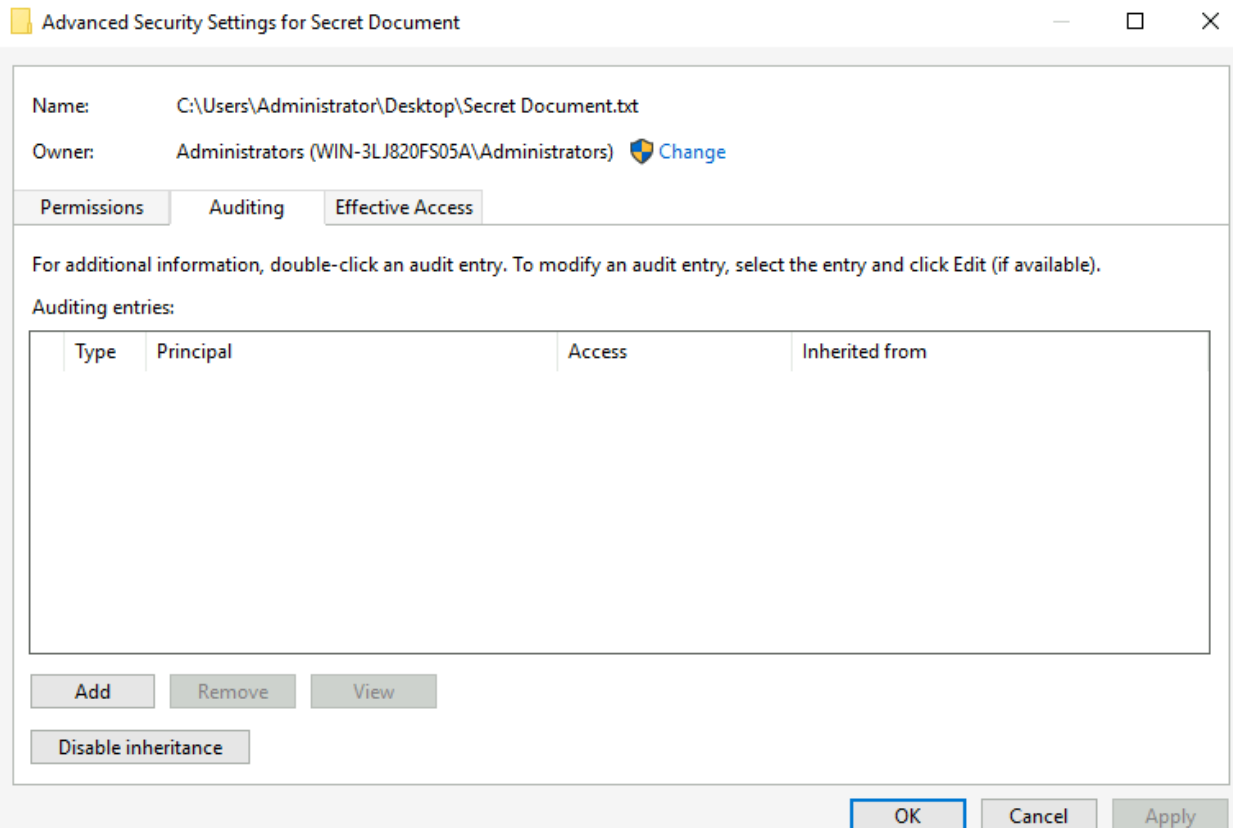
The way honeypots work is that they serve no legitimate business purpose, so any activity concerning them should raise immediate red flags. Hidden files and folders, on the other hand, are not meant to even be seen by normal end users, and so it works best when dealing with crawlers like worms making them particularly effective to detect intrusions.

Once the machine has initiated, click on the start icon and type "Local". The Local Security Policy application should appear. Open the application, then navigate to Security Settings → Local Policies → Audit Policy.

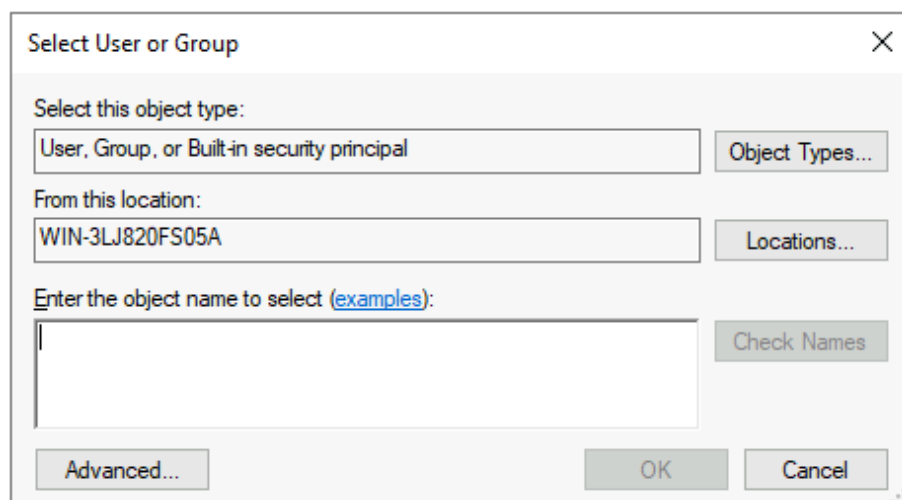


Open the **Audit object access** policy, tick the boxes beside Success and Failure, click Apply, and finally click OK. This entails that all access attempts will be logged, regardless of whether it succeeded. Once you're done, you may proceed to close the Local Security Policy application.

After configuring the Local Security Policy, nothing new will immediately happen by default. We have to specify in the actual file or folder that we intend to monitor it and as such, for our purposes, we will create a fresh file wherein our tripwire setup can be implemented and consequently observed. Right-click anywhere on the desktop → New → Text Document. A new unnamed text file will appear on the Desktop, and we can name it "Secret Document". Right-click the document → Properties → Security → Advanced → Auditing.



This is where we will create and specify an audit entry for our Secret Document. Click on Add → Select a principal.



This particular pop-up is where we can specify which users or groups we want to be alerted on whenever they access our Secret Document. You have a choice to be

very granular, but for our purposes, we intend to be general and so, on the text box, write "Everyone", then press Enter.

Auditing Entry for Secret Document

Principal: Everyone [Select a principal](#)

Type: Success

Basic permissions: [Show advanced permissions](#)

- ☐ Full control
- ☐ Modify
- ☒ Read & execute
- ☒ Read
- ☐ Write
- ☐ Special permissions

[Clear all](#)

OK Cancel

The Principal should now reflect "Everyone" and the permissions should now allow granular selection. Here you can specify all the activities on our Secret Document you want to audit. You can toggle to the advanced permissions via the Show advanced permissions on the upper right-hand corner of the area for an even broader selection of activities. Click OK when you're done exploring, and then click Apply and OK on the Audit entry page. Finally, we click on OK on our Secret Document properties.

An important note here is if you intend to track multiple files, it is recommended to have them categorized into folders so as to make it easier to audit their access.

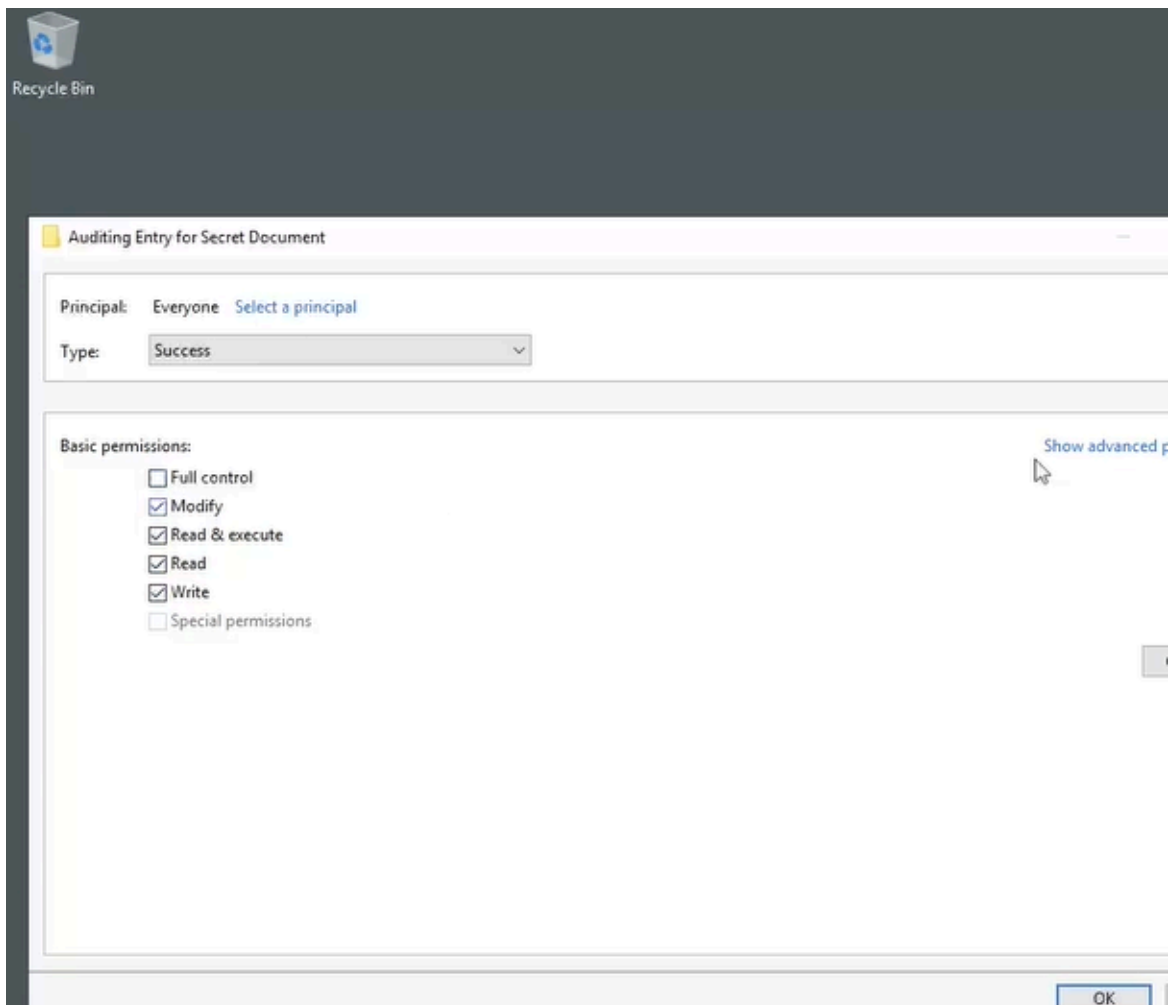
At this point, the setup is complete and auditing is active for our Secret Document. Anyone who accesses it will be logged and its details will be recorded in the Security event log with an Event ID 4663. This Event ID, along with the other Object Access Event IDs, can then be filtered and furnished into alerts that would

immediately tell your analysts of tripwires being activated, immediately giving value to the organization's security.

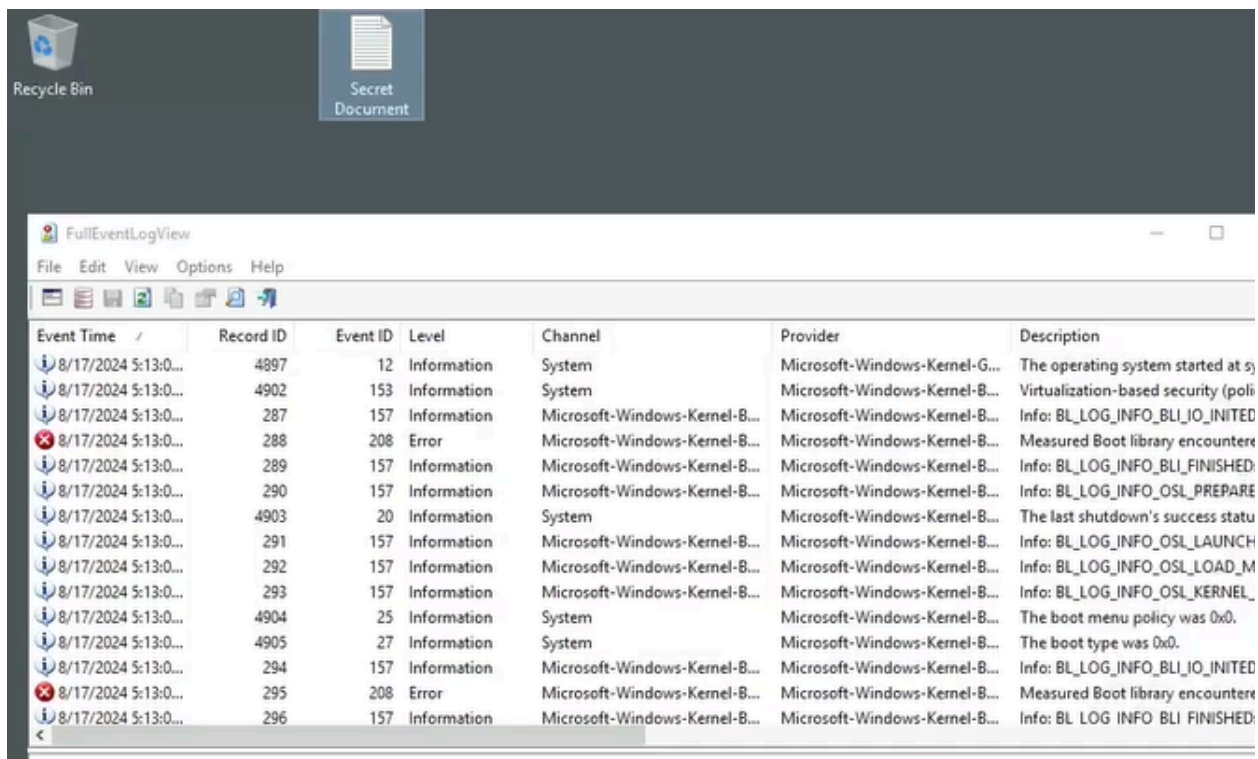
More info about Object Access Events, and the Audit Object access in general can be read [here](#)(opens in new tab).

Answer the questions below

The FullEventLogView application comes installed on your Windows machine. Use it for the following questions. What is the "Accesses" value in the log details when you try reading our Secret Document's contents via cmd? ReadData (or ListDirectory)s



(Then click show advanced permissions. Create an Secret Document txt file on desktop. Then open FullEventLogView application)



Open cmd go to Secret Document .txr directory

```

Administrator: Command Prompt
08/20/2022 11:31 AM <DIR> OneDrive
06/29/2022 01:09 AM <DIR> Pictures
06/29/2022 01:09 AM <DIR> Saved Games
06/29/2022 01:09 AM <DIR> Searches
05/22/2022 12:32 AM 8,364,400 setup.exe
06/29/2022 01:09 AM <DIR> Videos
5 File(s) 8,368,960 bytes
16 Dir(s) 31,111,114,752 bytes free

C:\Users\Administrator>cd Desktop
C:\Users\Administrator\Desktop>dir
Volume in drive C has no label.
Volume Serial Number is 348C-7C4F

Directory of C:\Users\Administrator\Desktop

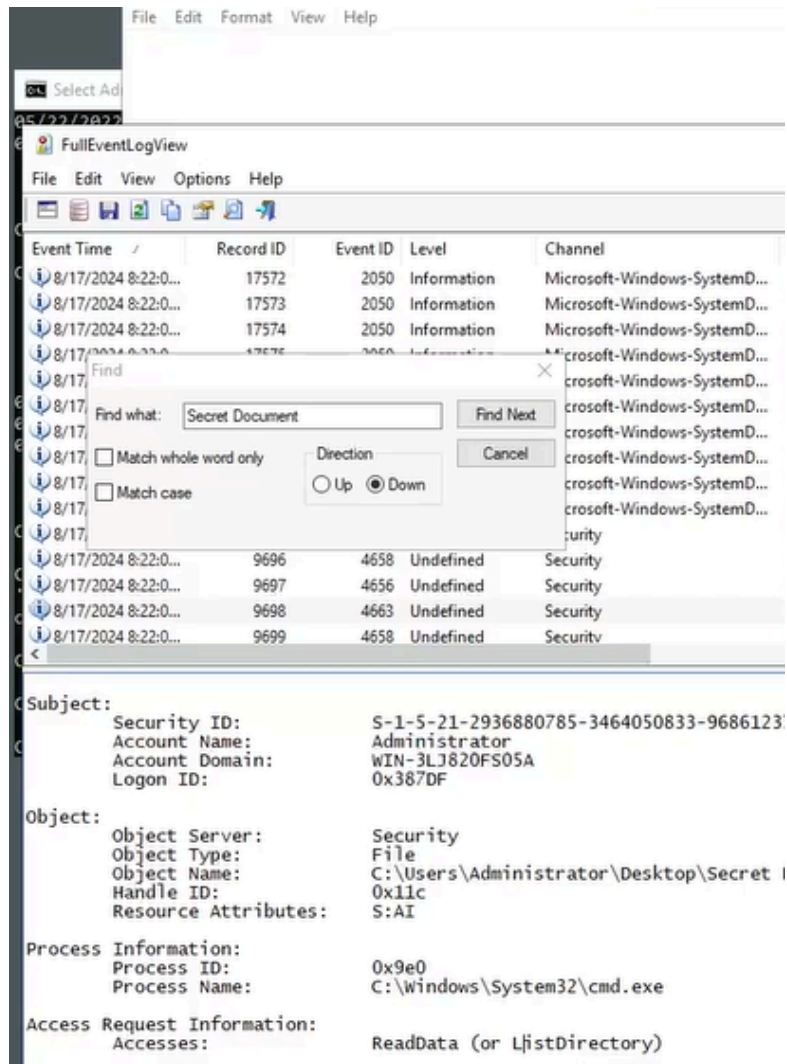
08/17/2024 08:14 PM <DIR> .
08/17/2024 08:14 PM <DIR> ..
08/17/2024 08:13 PM 0 Secret Document.txt
1 File(s) 0 bytes
2 Dir(s) 31,111,114,752 bytes free

C:\Users\Administrator\Desktop>type "Secret Document.txt"

C:\Users\Administrator\Desktop>open "Secret Document.txt"
'open' is not recognized as an internal or external command,
operable program or batch file.

C:\Users\Administrator\Desktop>

```



Event ID 4663 is always preceded by? 4656

FullEventLogView

File Edit View Options Help

Event Time	Record ID	Event...	Level	Channel	Provider	Description
8/17/2024 8:17:0...	9602	4656	Undefined	Security	Microsoft-Windows-Security...	A handle to an object was re
8/17/2024 8:17:0...	9589	4656	Undefined	Security	Microsoft-Windows-Security...	A handle to an object was re
8/17/2024 8:17:0...	9590	4656	Undefined	Security	Microsoft-Windows-Security...	A handle to an object was re
8/17/2024 8:17:0...	9601	4656	Un...	Security	Microsoft-Windows-Security...	A handle to an object was re
8/17/2024 8:14:0...	9577	4656	Un...	Security	Microsoft-Windows-Security...	A handle to an object was re
8/17/2024 8:17:5...	9659	4656	Un...	Security	Microsoft-Windows-Security...	A handle to an object was re
8/17/2024 8:17:0...	9600	4656	Un...	Security	Microsoft-Windows-Security...	A handle to an object was re
8/17/2024 8:17:5...	9658	4656	Un...	Security	Microsoft-Windows-Security...	A handle to an object was re
8/17/2024 8:17:0...	9594	4656	Un...	Security	Microsoft-Windows-Security...	A handle to an object was re
8/17/2024 8:17:0...	9595	4656	Un...	Security	Microsoft-Windows-Security...	A handle to an object was re
8/17/2024 8:17:0...	9596	4656	Un...	Security	Microsoft-Windows-Security...	A handle to an object was re
8/17/2024 8:17:0...	9597	4658	Undefined	Security	Microsoft-Windows-Security...	The handle to an object was
8/17/2024 8:17:0...	9598	4658	Undefined	Security	Microsoft-Windows-Security...	The handle to an object was
8/17/2024 8:22:0...	9703	4658	Undefined	Security	Microsoft-Windows-Security...	The handle to an object was
8/17/2024 8:17:0...	9593	4658	Undefined	Security	Microsoft-Windows-Security...	The handle to an object was

Find what: 4663

Match whole word only ☐

Match case ☐

Direction: ☐ Up ☒ Down

Find Next Cancel

A handle to an object was requested.

Subject:

Security ID: S-1-5-21-2936880785-3464050833-968612378-500

Account Name: Administrator

Account Domain: WIN-3LJ820FS05A

Logon ID: 0x387DF

Object:

Object Server: Security Account Manager

Object Type: SAM_DOMAIN

Object Name: WIN-3LJ820FS05A

Handle ID: 0x2be4f1660d0

Resource Attributes: -

What Event ID signifies the closure of an "object"? 4658

FullEventLogView

File Edit View Options Help

Event Time	Record ID	Event...	Level	Channel	Provider	Description
8/17/2024 8:22:0...	9737	4658	Undefined	Security	Microsoft-Windows-Security...	The handl
8/17/2024 8:18:0...	9681	4658	Undefined	Security	Microsoft-Windows-Security...	The handl
8/17/2024 8:17:5...	9662	4658	Undefined	Security	Microsoft-Windows-Security...	The handl
8/17/2024 8:22:0...	9709	4658	Un...	Security	Microsoft-Windows-Security...	The handl
8/17/2024 8:18:0...	9683	4658	Un...	Security	Microsoft-Windows-Security...	The handl
8/17/2024 8:22:0...	9712	4658	Un...	Security	Microsoft-Windows-Security...	The handl
8/17/2024 8:22:0...	9699	4658	Un...	Security	Microsoft-Windows-Security...	The handl
8/17/2024 5:14:10.837 PM	9149	4663	Un...	Security	Microsoft-Windows-Security...	An attemp
8/17/2024 5:14:1...	9151	4663	Un...	Security	Microsoft-Windows-Security...	An attemp
8/17/2024 5:14:1...	9153	4663	Un...	Security	Microsoft-Windows-Security...	An attemp
8/17/2024 5:14:1...	9155	4663	Un...	Security	Microsoft-Windows-Security...	An attemp
8/17/2024 5:14:1...	9157	4663	Undefined	Security	Microsoft-Windows-Security...	An attemp
8/17/2024 5:14:1...	9159	4663	Undefined	Security	Microsoft-Windows-Security...	An attemp
8/17/2024 5:14:1...	9145	4663	Undefined	Security	Microsoft-Windows-Security...	An attemp
8/17/2024 5:14:1...	9161	4663	Undefined	Security	Microsoft-Windows-Security...	An attemp

Find what: 4663

Match whole word only ☐

Match case ☐

Direction: ☐ Up ☒ Down

Find Next Cancel

Event ID 4658 helps determine how long a specific object was open.

What description field will you check in between events to be able to do so?

Handle ID (Checked on the web:

<https://www.ultimatewindowssecurity.com/securitylog/encyclopedia/event.aspx?eventid=4658>)

Description Fields in 4658

Subject:

The user and logon session that opened and now closed the object.

- Security ID: The SID of the account.
- Account Name: The account logon name.
- Account Domain: The domain or - in the case of local accounts - computer name.
- Logon ID is a semi-unique (unique between reboots) number that identifies the logon session. Logon ID allows you to correlate backwards to the logon event (4624) as well as with other events logged during the same logon session.

Object:

This is the object upon whom the action was attempted.

- Object Server: always "Security"
- Handle ID: is a semi-unique (unique between reboots) number that identifies all subsequent audited events while the object is open. Handle ID allows you to correlate to other events logged (Open [4656](#), Access [4663](#), Close [4658](#))

Process Information:

Process ID is the process ID specified when the executable started as logged in [4688](#). The Process Name identifies the program executable that accessed the object.

Task 5 - Purple Teaming

To cap this room off is a quick lesson on one of the best ways to strengthen an organization's overall security posture - by leveraging purple team tactics. A couple of rooms that showcase purple teaming are the [Tempest](#) and [Follina \(CVE-2022-30190\)](#) rooms.

The idea is simple: if you want to see how your defenses fare against an attack, understand how a certain vulnerability works and what it looks like on the logs, or you simply want to know the extent of your visibility on your environment - simulate an attack and then check the results.

Consequently, reflect on the following questions:

- What are the attacker techniques that you did?
- Which ones did you detect?

- Which ones flew under the radar?

The ones that you detected will affirm that you're doing a good job in those areas, whereas the ones you failed to detect constitute improvements that are ought to be made in your visibility and/or detection mechanisms.

Quick Discussion for Tempest: For the Tempest room, the room creator designed a full attack chain and emulated an adversary from start to finish, collecting valuable logs and showcasing detection and analysis tools as the room progresses. This is a classic example of the application of purple team tactics. The goal is to understand how logs will look like when specific attack techniques are being implemented against your environment.

Quick Discussion for Follina MSDT: From the Follina MSDT room, the room creator focused on the effects of the exploitation of the vulnerability in the environment and introduced how reviewing logs and process artifacts compliments publicly available IOCs.

From these findings, you can furnish alerts from the artifacts you've collected as well as from findings that you're able to observe via your logging mechanisms. These are just a couple of ways to leverage purple team tactics, and both show emphasis on how effective it is when leveraged well.

Answer the questions below

Fill in the Blanks: The Tempest and Follina rooms are examples of leveraging _____ tactics. Purple Team

What CVE is the Follina MSDT room about? Answer Format: CVE-XXXX-XXXXX.
CVE-2022-30190

Task 6 - Room Recap

This room explored some of the simplest ways that an organization can leverage immediately available information, "knowing your environment", and purple team tactics to develop a more robust detection mechanism - one that is more suited for each unique environment. In a world of purchase-deploy-and-forget, these tactics aim to provide an additional layer of security that would immediately be of value to wherever they are applied.

This room has also emphasized the value of layering defenses. It is never a good idea to put all your eggs in one basket in the same way that an organization shouldn't put all their time, money, and reputation on the shoulders of one method of detection and/or prevention. No method is perfect, so having depth in these defensive methods would allow for more opportunities to catch the bad guys.

Finally, a couple of rooms that leverage purple team tactics have been the chosen method of closing this topic.